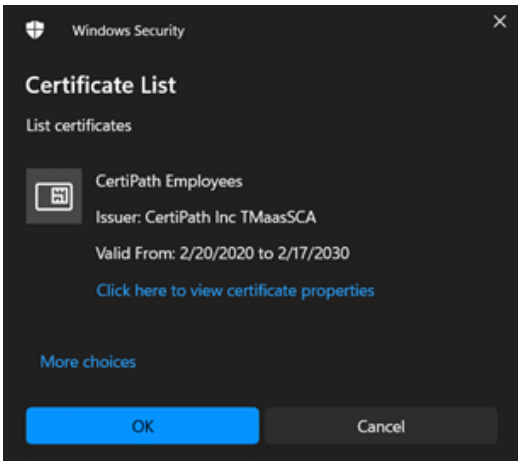
Configure Smart Card Logon on Windows Domains

idmanagement.gov/implement/scl-windows



September 2024 - Update to Microsoft Network Authentication Issue

As of September 10th 2024, Microsoft has released a solution for Active Directory network authentication issues resulting from the May 2022 patches that impacted some PIV network authentications. The September feature preview applies to Windows Server 2019 and later and includes a mechanism for support of some deprecated identifiers asserted by PIV authentication certificates (e.g., UPN or X509IssuerSubject altsecid) and mapped to AD user accounts. Once the September feature preview is installed and the servers are restarted, AD administrators will have the ability to add registry keys that include what is being termed a "Triple Mapping" or "Policy Tuple" that allows the domain controller to determine if an authentication certificate is issued from a trusted Certification Authority (CA) and if it asserts an acceptable policy OID before defining acceptable identifiers for user account mapping. You can read more about these AD changes in the following Microsoft Public Sector Blog and you may find additional installation and configuration instructions at the CISA Connect.gov site (PIV/CAC authentication available). Full enforcement mode for use of approved identifiers is still planned to go into effect on February 11, 2025 and compatibility mode will be fully retired on September 10th, 2025. See Step 4 below regarding Account Linking for further details.

Approved AltSecID Identifiers

If your on-premise Active Directory user account mappings already use X509SKI or X509IssuerSerialNumber altsecid, you will not need to take any action as a result of the September 2024 Microsoft updates.

Introduction

These Windows Domain configuration guides will help you configure your Windows *network domain* for smart card logon using PIV credentials.

There are many useful pages and technical articles available online that include details on configurations and using generic smart cards. The information presented here addresses common questions and configurations **specific** to the U.S. federal government, **PIV** smart cards, and U.S. federal civilian agency certification authorities.

Teamwork

Work with your Network Engineers, Domain Admins, Account Management, and Information Security colleagues to review the information, perform the configurations, and troubleshoot any issues.

Pre-Launch Checklist

Check the following items **before** reviewing these network guides and lessons learned:

1. Users have PIV credentials and PIV card readers.
2. You are using Microsoft Active Directory to manage your Windows network.
3. Domain Controllers are running Microsoft Windows Server 2019 or newer.
4. User workstations **are joined** to your network and are Windows 10 or newer.

Configuration Checklist

There are five configuration categories to review with your colleagues. All five include steps that must be completed; it's best to review and complete the configuration categories in this order:

1. Network Ports and Protocols
2. Domain Controllers
3. Trust Stores
4. Account Linking: Associating PIV credentials with User Accounts
5. Group Policies and Enforcement

There are five additional guides:

1. Network Tuning
2. Local Certification Authority
3. Authentication Assurance

We want to add additional information for installing Online Certificate Status Protocol (OCSP) services, addressing common errors and troubleshooting, and configuring for other operating systems.

Submit an Issue to identify information that would be helpful to you, or consider contributing a page to these guides with your lessons learned.

Step 1 - Network Ports and Protocols

Your workstations, servers, network domain controllers, and applications need to validate the revocation status of the PIV certificates and all intermediate certificate authority (CA) certificates. In addition, the certificate chain path building may retrieve and download the intermediate CA certificates.

The validation occurs in real time (with some caching) and requires ensuring network traffic is open and available to the destination web services, ports, and protocols. Many U.S. federal agencies implement a layered network security model with demilitarized zones (DMZs), proxies, and Trusted Internet Connections (TICs) to monitor, defend, and protect the networks, applications and users.

Verifying and Troubleshooting

Non-accessible endpoints for the web services due to firewalls blocking access is a very common root cause for errors. If you encounter user errors including "Cannot validate" and similar domain controller errors, your first troubleshooting step should be to verify your network and access.

nslookup and certutil are your friendly tools

Restricted or denied access to Internet web services including the OCSP and CRL web services used in the certificate validations lead to common errors and issues. Collaborate with your Network Engineers to review the web services, IP addresses, ports and protocols, and verify access from all local and wide-area network segments.

It is simple to begin troubleshooting if the web services endpoints are accessible or blocked by firewall rules. You have the basic four utility tools for troubleshooting:

- certutil (Microsoft)
- openssl
- nslookup
- tracert

For the typical network domain, *certutil* will be your best option to identify a number of possible root causes. There are many options available in the *certutil* utility tool, and two are covered here.

Export your *public* key and certificate for PIV Authentication to a .cer file (mypiv_auth.cer), and run the following command in a command line from workstation(s) *and* domain controller(s):

```
certutil -verify -urlfetch mypiv_auth.cer >>verify_piv.txt
```

The text file output will include a *full* check against all options for CRLs, OCSP, intermediate certificates to verify a trust chain, and the root (COMMON). Review all items and ensure at least one successful verification message is included for *each check*. You may see errors for the LDAP verifications and these can be ignored if a CRL or OCSP check is successful.

Time is important

When reviewing the verification messages, you should pay careful attention to the time. For example, if a CRL file is not downloaded in under 15 seconds, it is very likely that you will encounter network authentication errors and will need to perform some tuning.

There is also a graphical user interface to help perform these verification checks.

```
certutil -v -url mypiv_auth.cer
```

The graphical user interface allows you to check OCSP, CRL, and AIA (intermediate certificate retrievals).

Can federally operated certificate revocation services (CRL, OCSP) operate on port 80?

Yes. This very narrow class of services, that provide CRL and OCSP information for the purposes of verifying the revocation status of certificates used to make other HTTPS connections, should abide by best practices in the field and their respective specifications. For CRLs, follow RFC 5280 which states CAs **SHOULD NOT** include URIs that specify https, ldaps, or similar schemes in extensions. For OCSP, follow RFC 6960 which states a CA may use port 443 for OCSP where privacy is a requirement. Agencies are encouraged to operate OCSP and CRL services via hostnames specifically reserved for those services, so that other related information and functionality can be served securely and privately. For more information see the Federal CIO Council HTTPS-Only Standard .

Web Services for Validating PIV Certificates

Revocation status is validated using using either Online Certificate Status Protocol (OCSP) or Certificate Revocation Lists (CRLs). To meet your initial network requirements, you should ensure the OCSP and CRL URLs included in *your agency* users' PIV Credential Certificates are accessible from all workstations and domain controllers.

Type	Certificate Extension	Protocol (Port)	Considerations
OCSP	Authority Information Access	HTTP (80)	All PIV certificates have OCSP references and OCSP URLs which are Internet accessible and provided by the issuing CA. Intermediate CAs are **not** required to have OCSP available for the *intermediate* certificates.

Type	Certificate Extension	Protocol (Port)	Considerations
CRL	CRL Distribution Point (CDP)	HTTP (80)	All PIV certificates have CRL capabilities provided by the issuing CA. All intermediate CA certificates have CRL capabilities. CRL files have an expiration time that varies between 6 to 18 hours. CRL file sizes range from a few kilobytes to more than 30 megabytes (MB).

Lightweight Directory Application Protocol (LDAP) for retrieving information is not preferred and has been increasingly deprecated; therefore, LDAP is not included.

There are dozens of OCSP and CRL URLs for *all* issued PIV credentials. If you have users with PIV credentials from other agencies or partners, identifying all the URLs to verify against your network configurations will be more complex.

Externally Issued PIV Revocation Resources

You can find end-entity CRL Distribution Point and OCSP URIs under our Active PIV Issuing CA page in the event you require revocation information for externally issued PIV CAs.

Web Services for the Federal Public Key Infrastructure

The Federal Common Policy Certificate Authority G2 (COMMON) is the root certificate authority and has web services to publish both certificate chains (p7b files) and CRLs for all intermediate certificate authorities which the root signs.

To enable communications with these Federal Common Policy Certificate Authority services, including those currently operational and any expansion, you should verify outbound communications to the base domain of *http.fpki.gov*. For example, a successful connection to http://repo.fpki.gov/fcpca/fcpcag2.crt will download a copy of the Federal Common Policy CA certificate.

You should consider allowing two protocols (ports): HTTP (80) and DNS (53). Although the web services for publishing CRLs are not currently served over HTTPS (443), you may want to allow HTTPS (443) to future proof for any expansion.

Step 2 - Domain Controllers

To use smart cards and PIV credentials for network authentication, all domain controllers need to have domain controller authentication certificates.

Devices authenticate too!

When your users are using certificates to authenticate to the network, the domain controllers are also authenticating as devices using certificates. Each works together to create secure connections. To learn more, search for online resources that discuss Public Key Cryptography for Initial Authentication (PKINIT) protocols.

This page contains information on domain controller certificate profiles and issuing domain controller certificates.

Domain Controller Certificate Profiles

Domain controller certificates must be issued with a set of specific extensions and values. The certificate profile for each domain controller must meet the following requirements:

- The certificate **Key Usage** extension must contain:

```
Digital Signature, Key Encipherment
```

- The certificate **Enhanced Key Usage** extension must contain:

```
Client Authentication (1.3.6.1.5.5.7.3.2)
Server Authentication (1.3.6.1.5.5.7.3.1)
```

- The certificate **Subject Alternative Name** extension must contain the Domain Name System (DNS) qualifier and fully qualified domain controller name. For example:

```
DNS Name=controller1.intranet.agency.gov
```

- The certificate **Subject Alternative Name** must also contain the domain controller's Global Unique Identifier (GUID) (i.e., for the "domain controller object").
  - To determine the domain controller's GUID, start **Ldp.exe** and locate the **domain-naming context**.
  - Double-click on the **name of the domain controller** whose GUID you want to view.

    > The list of attributes for the domain controller object contains **"Object GUID" followed by a long number**. The number is the object GUID. For example:

    ```
    Other Name: 1.3.6.1.4.1.311.25.1 = ac 4b 29 06 bb d6 5d 4f e3 9c 4c ab c3 6a 55 d9
    ```

    > The domain controller's certificate must be installed in the domain controller's local computer's ***personal certificate store***.

Supported Domain Controller Identifiers

Many Domain Controllers are issued device certificates via Active Directory Certificate Services (ADCS) that may be operating an Only Locally Trusted PKI also known as an "Enterprise" PKI. Those ADCS implementers will want to include the Microsoft proprietary Security Identifier (SID) in their DC certificate profile to ensure compliance with recent Microsoft changes. For other AD implementers who receive DC certificates from their PIV Shared Service Provider, you may want to work with that provider to include the SID in any renewed or rekeyed DC certificates.

> It is also recommended to include a non-critical Security Identifier (ObjectSID) extension in your DC certificates, for example:

```
1.3.6.1.4.1.311.25.2 = S-1-5-domain-516
```

Avoid Vulnerabilities with Device Identifiers

Vulnerabilities identified in CVEs reported in May 2022 have outlined potential avenues for network authentication based on spoofed or emulated device certificates that have not been issued by trusted CAs. In order to avoid these vulnerabilities, AD implementers must prohibit the use of any non-person entity (NPE or Devices to include DCs) certificates issued by CAs listed in GPO policy tuples. Please see the following Microsoft Knowledge Blog for additional specifics regarding these vulnerabilities.

Issue Domain Controller Certificates

U.S. federal civilian agencies have a variety of information security policies. These policies cover whether you should use a domain controller certificate issued from your agency's local enterprise certification authority (CA) or whether the certificate must be issued from a CA managed and certified under the Federal Public Key Infrastructure (FPKI). Each agency's information security policy should be followed.

It is not recommended to set up a local enterprise CA just to issue domain controller certificates without ensuring the proper management and security protections are enabled. Your Chief Information Security Officer (CISO) must have awareness and oversight established for the CA management.

Collaborate with your CISO or Information Security Office for a definitive answer and direction.

If you do have a local enterprise CA, .

Step 3 - Trust Stores

Follow [Step 3 - Distribute to Operating System from the distribute FCPCA configuration guide](#).

Mutual Trust

Note that both the client machine and domain controller trust stores must be configured for mutual authentication. As a result, the domain controller issuing and root CA certificates needs to be included in the client trust store and the client PIV authentication issuing, intermediate and root certificates need to be able to be trusted by the domain controller.

Step 4 - Account Linking

Account linking refers to the process of associating a certificate on a user's PIV credential with their domain account.

Comparing altSecurityIdentities and User Principal Name

There are two account linking attributes to choose from:

- altSecurityIdentities (*recommended*)
- User Principal Name (UPN)

It's not possible to configure a domain to use *both* altSecurityIdentities *and* User Principal Name mapping. You must choose **one** of these options and configure its use for *all* domain users.

altSecurityIdentities Approach

- Each PIV credential can be associated with **more than one** account.
  This flexibility allows for the association of a single PIV credential certificate to an individual's end-user and privileged user account(s).
- Users are presented with an additional field during network authentication to identify which account the user wants to access. This field is known as the *User Name Hint*.
  - The User Name Hint informs Windows which account the user is trying to log in to if the mapped certificate is associated with multiple accounts.
  - Entering a User Name Hint is optional if the user's PIV Authentication certificate UPN matches their Windows logon name.
- You can choose from one of six options to map a certificate to a given account.
- There is more flexibility for accepting PIV credentials issued by other government agencies or partners, including PIV-Interoperable (PIV-I) credentials.

User Principal Name Approach

- Each PIV credential can only be associated with **one** account.
- The UPN value from the *Subject Alternate Name* in the PIV Authentication certificate is required.
- There is no flexibility for associating the PIV credential to separate privileged accounts.
- There is less flexibility for accepting PIV credentials issued by other government agencies or partners, including PIV-I credentials.

Transitioning from UPN Mapping to altSecurityIdentities Mapping

If you have a large network with many domains, you should carefully plan the migration from User Principal Name to the altSecurityIdentities account linking method.

Use of UPN by Applications

You may find that you have many applications that rely on User Principal Name values. There is no need to remove existing or stop populating new User Principal Name values in your transition to altSecurityIdentities.

There are three steps to implement altSecurityIdentities account linking:

1. Link the PIV Authentication Certificate
2. Enable User Name Hints
3. Disable User Principal Name Mapping

Option 1. Link the PIV Authentication Certificate

First, you need to link each user's PIV Authentication certificate to their domain account(s). This is accomplished by populating data extracted from the user's PIV Authentication certificate into their Active Directory record, specifically into the **altSecurityIdentities** attribute.

Adding altSecurityIdentities attributes **will not** break existing UPN account linking or cause smart card logon to fail. It's possible to plan your transition carefully and to take your time populating the altSecurityIdentities attribute for domain users.

There are six altsecid mapping options to choose from; however, three of these are considered to be "weak" identifiers that will either need to be migrated to a "strong" identifier or policy table mappings will need to be implemented to allow for use of an Issuer/Subject altsecid.

Depricated Mappings

As of September 2024, Microsoft has depricated the use of Subject and RFC822 altsecid mappings as they were considered vulnerable to spoofing attempts.

Options	Tag	Example	Strength	Considerations
Issuer and Subject	X509:<I><S>	X509:<I>C=US,O=U.S. Government, OU=Certification Authorities,OU=Government Demonstration CA <S>C=US,O=U.S. Government, OU=Government Agency, CN=JANE DOE OID.0.9.2342.19200300.100.1.1=47001003151020	Supported with Policy Tuple	Implementers will need to leverage a policy tuple to accomodate this altsecid. Note the spaces carefully when testing machine-readable formats of the certificate extensions versus the human-readable formats.
Issuer and Serial Number	X509:<I><SR>	X509:<I>C=US,O=U.S. Government, OU=Certification Authorities, OU=Government Demonstration CA <SR>46a65d49	Supported	Serial number is stored in a reversed byte order from the human-readable version, starting at the most significant byte.

Options	Tag	Example	Strength	Considerations
Subject Key Identifier	X509: 	X509: <SKI>df2f4b04462a5aba81fec3a42e3b94beb8f2e087	Supported	Highly unique; may be difficult to manage.
SHA1 hash of public key	X509: <SHA1-PUKEY>	X509: <SHA1-PUKEY>50bf88e67522ab8ce093ce51830ab0bcf8ba7824	Supported	Highly unique; may be difficult to manage.
Subject	X509:<S>	X509: <S>C=US,O=U.S. Government, OU=Government Agency, CN=JANE DOE OID.0.9.2342.19200300.100.1.1=25001003151020	Deprecated	This field is no longer supported for altsecid mapping as of Sept 2024.
RFC822 name	X509: <RFC822>	X509: <RFC822>john.smith@hhs.gov	Deprecated	This field is no longer supported for altsecid mapping as of Sept 2024.

Use of Security Identifiers (SID)

Although it is not mandated by FPKI PIV certificate profiles, an SID is a Microsoft priorietary identifier that can be asserted as a non-critical extension in a PIV authentication certificate and used for AD user account mapping.

Policy tuple mappings to accomodate some weak identifier mappings are available in Windows Server 2019 and later as of September 10th, 2024. Tuple mappings are defined via group policy, specifically *Administrative Settings / System / KDC* under an entry titled **"Allow name-based strong mappings for certificates"** wherein administrators can define three things to include:

1. Trusted issuing CA - identified by its certificate thumbprint, each tuple will be unique to each issuing CA thumbprint
2. Trusted certificate policy OID - ensures that the client certificate is issued acording to a certain policy or policies, and
3. Name matching - defines what field to extract from the certificate that meets the previous two conditions for correlation to AD user accounts, this will generally be UPN suffix and/or altsecid IssuerSubject

Note that if you authenticate PIV certificates from multiple issuing CAs you will require several registry entries with the tuple mapping to account for the unique thumbprints of each issuing CA.

The following examples provide a few options for various potential policy tuple values that can be used to identify a few types of certificate based network authentication credentials.

1. UPN only policy tuple for a standard internal PIV user (Entrust Managed Services SSP CA, PIV Authentication OID, Department of Health and Human Services UPN Suffix)

```
19fea49c468760edce9600a9da9657b484734d24; 2.16.840.1.101.3.2.1.3.13; UPNsuffix=hhs.gov
```

2. Altsecid policy tuple for a priviledged administrator with an ALT token (Entrust Managed Services SSP CA, Common-Hardware Token, Issuer/Subject altsecid)

```
19fea49c468760edce9600a9da9657b484734d24; 2.16.840.1.101.3.2.1.3.7; IssuerSubject
```

3. Altsecid policy tuple for an external PIV or dPIV user (NASA Operational CA, PIV Authentication and dPIV Authentication OIDs, Issuer/Subject altsecid)

```
67ddd6f4be3b69568f591bf999db2ef3085f7c5bl, 2.16.840.1.101.3.2.1.3.13,
2.16.840.1.101.3.2.1.3.40; IssuerSubject
```

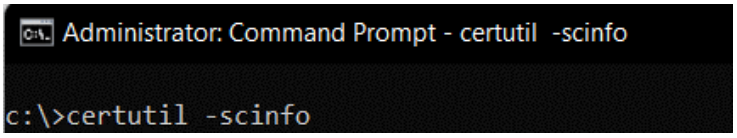
Identity certificates used for Windows logon can generally be found:

- On the smart card itself.
- By requesting the certificates directly from the smart card issuer (either the CA or RA).
- By exporting the certificates from a third party application in which the certificates are already registered.

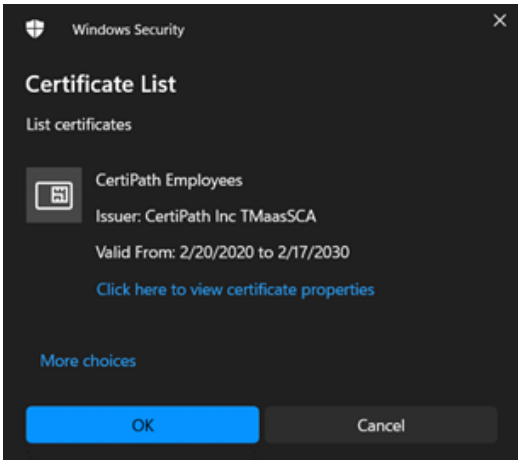
Each of these options is discussed below.

Gather Certificate from Smart Card
To gather the certificate from the smart card using a Windows workstation, have the cardholder do the following:

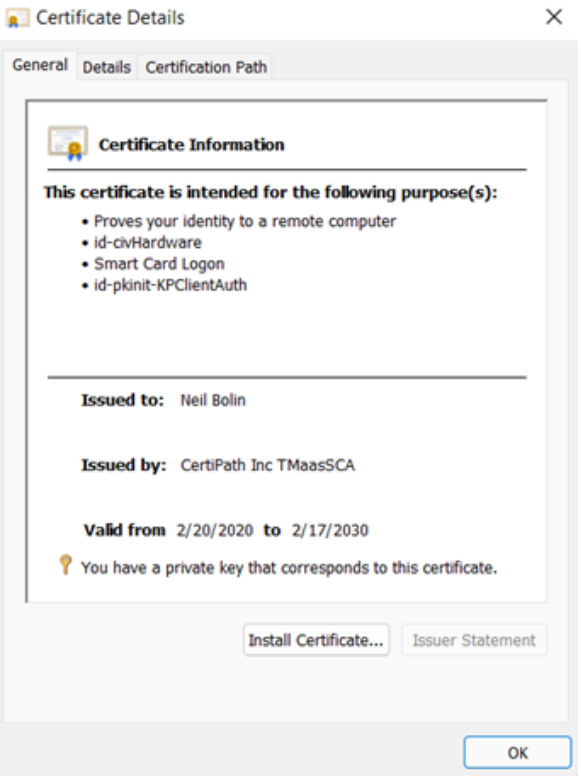
1. Open the Start Menu, located in the bottom left corner of the screen.
2. Type **command prompt**.
3. In the prompt, type **certutil -scinfo**.



4. Press **Enter**.
5. The cardholder will be prompted several times for a PIN, but a PIN is not required for this operation. Have the cardholder press **cancel** each time they are prompted for a PIN until they see the Certificate List.

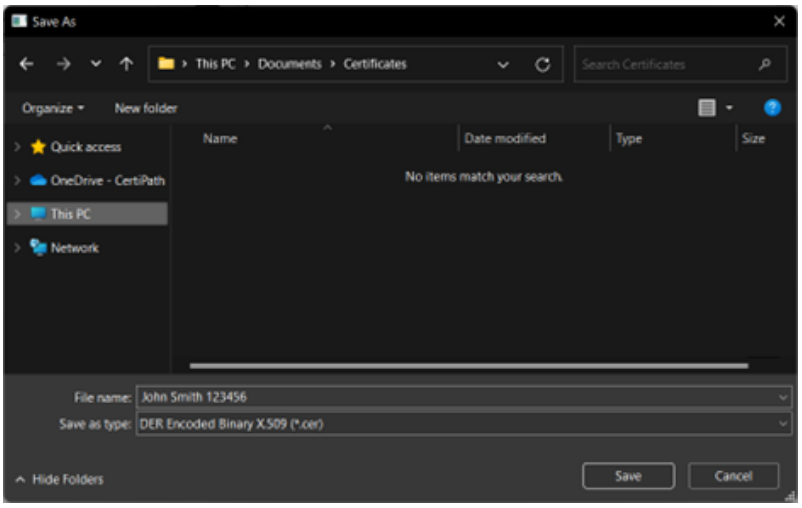


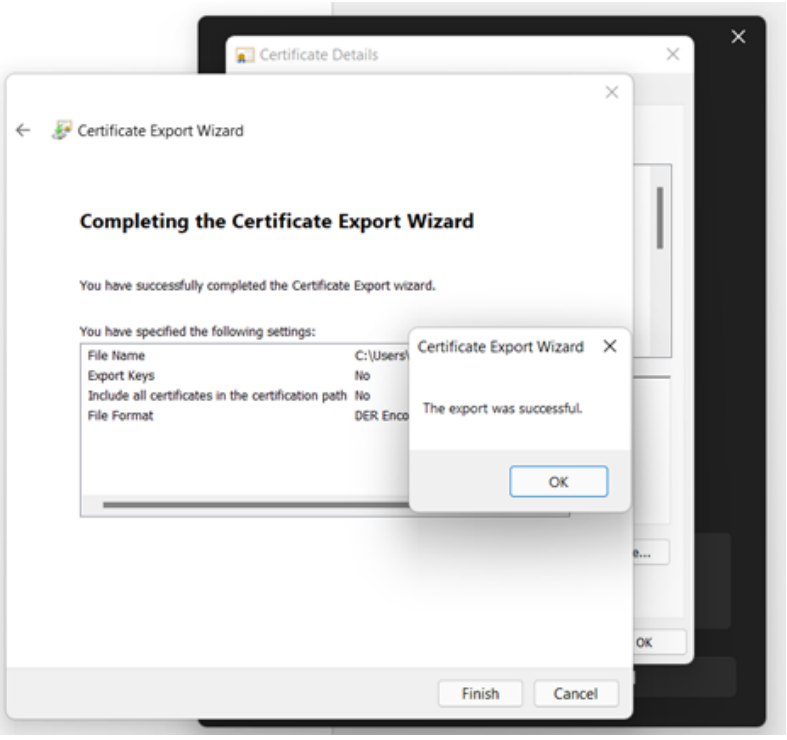
6. Have the cardholder click **Click here to view certificate properties**. The appropriate certificate will list “Smart Card Logon” in the intended purposes on the General tab. If the certificate has this purpose listed, have the cardholder proceed to Step 7. Otherwise, have the cardholder close the certificate, click **more choices** on the Certificate List, click another certificate in the list, and click **Click here to view certificate properties** until the correct certificate has been identified.



7. Have the cardholder select the **Details** tab and then proceed with the steps below.
8. Click **copy to file** to start the certificate export wizard.
9. Click **Next**.
10. Click **Next** again to indicate that the cardholder does not wish to export the private key.
11. Click **Next** again to use the default DER encoding.
12. Click **Browse** to select where to save the certificate. Have the cardholder select a location that he or she has permission to save to, such as Desktop or Documents.
13. Enter a meaningful name for the certificate (such as the cardholder’s name or employee ID).
14. Click **Save**.
15. Click **Next**.
16. Click **OK**.
17. Click **OK** to close the Certificate Details window.
18. Click **OK** to close the Certificate List.

19. Close the command prompt.





20. Have the cardholder send the exported .cer file to your organization's Network Administrator in a way that aligns with the organization's security policies.

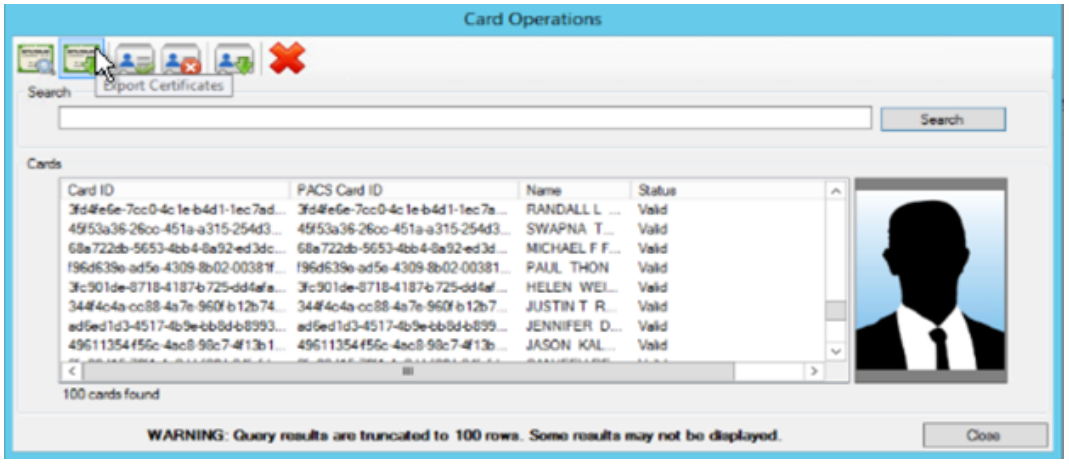
Request Certificates from the Smart Card Issuer

Your organization's credential issuer may have a copy of certificates issued to current users. You will need to specifically request from the issuer the most recent valid identity certificates suitable for smart card logon. The issuer will produce these certificates in a variety of ways, based on the certification authority or the Card Management System in use.

PIV Authentication Certificate Sources

USAccess customers can recieve PIV authentication certificates via their SIP interface. Reach out to usaccess at gsa dot gov for additional information.

Export Certificates from a Third Party System
Your organization may have already collected the relevant certificates as part of the enrollment process for a third party application, such as a FIPS 201-compliant PACS system. Depending on the system and configuration in use, you may be able to export your cardholders' certificates from the database where they are enrolled. Speak with your PACS integrator to understand what options are available to you.



Methods for Linking the PIV Authentication Certificate

System administrators can leverage one of the approaches below to link PIV Authentication certificates with user accounts. Run these steps from a domain controller with elevated privileges.

A. Use the Active Directory Users and Computers Graphical User Interface
The following steps are useful if you only need to update a small number of user accounts:

- **Start** > **Server Manager**
- **Tools** > **Active Directory Users and Computers**
- **View** > **Advanced Features**
- Expand your domain to reveal the **Users** directory
- Right-click on the user whose certificate you'd like to map and select **Name Mappings**
- Click **Add** and browse to a local copy of the user's PIV Authentication certificate
- Click **Apply** and then **OK**

B. Use Automation
If you are designing an automated process to transition users from Principal Name to altSecurityIdentities mapping, consider the following functionality:

- Load and process multiple certificates at once (for example, reading a directory of user certificates)
- Extract the UPN from each certificate and ensure a corresponding user record exists in Active Directory
- For certificates that contain a UPN that matches a record in Active Directory:
    - Extract and format the certificate Issuer and Subject attributes in preparation for publishing to Active Directory
    - Update the user's Active Directory record with the altSecurityIdentities attribute and corresponding Issuer and Subject data
- For certificates that do not contain a UPN that matches a record in Active Directory:
    Set aside for manual review (e.g., these users may be no longer affiliated with your organization)
- Evaluate accounts in Active Directory that do not contain an altSecurityIdentities attribute after process execution for manual review and further remediation

Collaborate with us!

We're working with a small number of agencies to pilot a simple PowerShell script to help with some of the functional requirements above. Check out the script in our public scripts repository or contact icam@gsa.gov for more information.

Option 2. Enable User Name Hints

You need to enable *User Name Hints* for your network domain. This will modify the logon prompts for *Windows* workstations and servers joined to the network domain. Your users will be prompted to provide both the PIV credential PIN value and a User Name Hint value.

For Windows Server 2012 and later:

- *Computer Configuration* > *Administrative Templates* > *Windows Components*, and then expand *Smart Card*.
- Select *Allow User Name Hint*

Management of smart card settings should be deployed using a group policy object for the domain.

Option 3. Disable User Principal Name Mapping

To transition from UPN mapping to altSecurityIdentities account linking, you will need to configure a registry setting on **all** domain controllers. Only configure the registry setting below once you have completed the above steps and are ready to disable UPN mapping.

Note: Organizations should carefully plan their transition to the altSecurityIdentities account linking approach and test interoperability before implementing changes in their production IT environments. **The registry configuration below will cause smart card logon to fail for any user missing the altSecurityIdentities attribute.**

- **Key:** HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Kdc
- **Name:** UseSubjectAltName
- **Type:** DWORD
- **Data (Value):** 00000000

This setting tells your network domain *I don't always want to use the Subject Alternate Name values for my user certificates.* More information on the setting is available here.

It's possible to revert to UPN account linking by removing the registry setting above.

Use group policy objects or other centralized management options to manage registry options.

Step 5 - Group Policies and Enforcement

Group Policy to Support "Weak" Identifiers

Administrators can enable **Allow name-based strong mappings for certificates**, in conjunction with policy tuple mappings mentioned in Step 4, to continue to use "weak" PIV alternate security identifiers for user account correlation.

The U.S. federal government publishes the United States Government Configuration Baseline (USGCB) for use by Executive Branch agencies to promote uniform configurations for commonly used operating systems. The USGCB configuration guidelines for specific operating systems include references to some configurations related to smart card (PIV) logon and should be referenced first.

The information on this page is intended to answer questions and identify the most commonly used configuration options. For a full reference of options for each operating system, please refer to configuration guides published by other sources online.

Machine Based Enforcement Versus User Based Enforcement

There are two options for requiring users to use PIV credentials to authenticate to the network domain:

- Machine Based Enforcement (MBE)
- User Based Enforcement (UBE)

These options are controlled by group policy applied to either Machine or User objects in your network domain. Planning is required to move to full User Based Enforcement and agencies are often using a combination of both Machine and User enforcement in their deployments.

User Based Enforcement

The user's password will no longer be known by the user. Look for agency internal applications that are still using username and password and performing Form Based Authentication against the network directories. Fix these using Kerberos, SAML, or direct x509 authentication.

Impacts and considerations are identified to help you plan and execute according to your agency network and user needs.

Type	Impacts	Considerations
Machine Based Enforcement	The user is required to use their PIV credential to authenticate to each device where the policy is applied.	The user password is maintained.
User Based Enforcement	The password stored for the user is removed and changed to a long hash value unknown to the user. Your users no longer have passwords for the network.	Any applications which were implemented to prompt your users for a username and password and which are using your network domain directories will no longer be accessible.

Your applications impacted by User Based Enforcement are designed or deployed using:

1. Form Based or Basic Authentication
2. or LDAP simple binds

The user will be presented with the application form to enter a username and password and the user will no longer have the password.

You want to analyze your applications and identify which are configured to use your users' network domain passwords. There are methods to fix the applications by enabling Kerberos, SPNEGO (web applications), direct x509 authentication (client certificate authentication), or the SAML and Open ID Connect (OIDC) protocols. These topics will be covered in the Applications section of the guides that are in-development and we invite *all* to contribute to them!

Defining the Policies for Machine Based Enforcement or User Based Enforcement

The setting to enforce PIV logon is controlled by **scforceoption** in your network domain user and workstation policies.

- Machine Based Enforcement is when you apply the **scforceoption** to a workstation or server object in your network domain.
- User Based Enforcement is when you apply the **scforceoption** to a user in your network domain.

This is the only difference when implementing the policy: which objects in your domain you apply the policy to.

You can set the policy option on a single user by checking the *Smart Card is required for interactive logon* check box in the user account properties. You can also apply this setting using group policy objects. When the **scforceoption** setting is applied, the SMARTCARD_REQUIRED flag is added to the UserAccountControl (UAC) and the DONT_EXPIRE_PASSWORD attribute is set to true.

Defining Kerberos Policies for Re-authentication

Although users can PIV authenticate to domain controllers, the client and the domain controller maintain those sessions using kerberos tickets.

Group policies can be configured by domain administrators to align with local security policies for maximum lifetimes of kerberos user tickets. This may cause users to be prompted to re-authenticate with their PIV when prompted with one of the following options:

- Windows Needs Your Current Credentials
- Please Lock this computer, then unlock it using your most recent password or smart card

These prompts happen when the kerberos ticket lifetime expires and a new authentication event is required. User is set to user based enforcement, which requires a new PKINIT event with the domain controller.

You can find additional information on configuring kerberos policies given the following reference documentation.

Step 6 - Network Tuning

You can tune the network domain settings to help you and your users have a better experience and reduce errors. This section highlights some of the *common* tuning configurations for network domain logon. There are additional tuning configurations and we encourage you to start with these first and contribute others.

You can also send questions to the ICAM Technology listserve (icam-community-tech-request@listserv.gsa.gov) to ask your government colleagues for their additional tips and tricks!

When a user authenticates to a Windows system, their logon credentials are cached to enable logon in the event the domain controller is unavailable. The United States Government Configuration Baseline (USGCB) for Windows 7 specifies that ***Interactive logon: Number of previous logons to cache (in case domain controller is not available)*** should be set to ***2***.

There are no required USGCB settings for *Windows 8* or *Windows 10*.

You should configure the cached logon credential limit to be at least “2” and *possibly more* depending on the mission needs.

The ***Number of previous logons to cache*** can be modified in local or group policy in the following location ***Computer Configuration\Windows Settings\Security Settings\Local Policies\Security options***

More information is available on Microsoft TechNet

CRL Retrieval Timeout Settings

By default, Windows will time out when downloading Certificate Revocation List(s) after 15 seconds. A number of CRLs in the government environment are large, greater than 20 MB in size, which will lead to the timeout happening. This example scenario can be common and a source of frustration to you and your users:

- The first or the 51st user will attempt to log on in the morning in a region
- The validity period and cache of the previous CRL will have expired on the domain controller
- The domain controller will attempt to download the large CRL file and will hit the timeout limit

- The user will receive an authentication failure (unable to log on)
- The user will be able to try again and be successful
- You will try to determine the root cause to diagnose the failures (i.e., chasing ghosts on the network)
- This process will repeat

You want to tune *both* the OCSP Response Caching Behavior setting and the CRL Retrieval Timeout Settings.

The default timeout value can be modified using local or group policy by modifying the ***Default URL retrieval timeout*** value found in the ***Certificate Path Validation Settings***, ***Network Retrieval*** tab, located in ***Computer Configuration\Windows Settings\Security Settings\Public Key Policies***

Consult these step-by-step instructions: Manage Network Retrieval and Path Validation

OCSP Response Caching Behavior

By default, Microsoft Windows will retrieve and cache 50 OCSP Responses for any one issuing CA before switching to CRL mode. Depending on the size of the CRL, this may be a poor performance decision. For environments where workstations routinely interact with large CRLs, a large value may significantly reduce network bandwidth consumption. This value can be increased by setting the ***CryptnetCachedOcspSwitchToCrlCount*** DWORD value in the following registry key: ***HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\SystemCertificates\ChainEngine\Config***

Source: Optimizing the Revocation Experience

Step 7 - Local Certification Authority

This page provides some tips for using a local certification authority (CA) to issue a domain controller certificate. This is for local Microsoft CAs. Other platforms may be used and have different procedures.

These procedures are accurate for using Microsoft 2012 Server, Standard Edition, for CA and domain controller servers as of March 2017.

Can federally operated certificate revocation services (CRL, OCSP) operate on port 80?

Yes. This very narrow class of services, that provide CRL and OCSP information for the purposes of verifying the revocation status of certificates used to make other HTTPS connections, should abide by best practices in the field and their respective specifications. For CRLs, follow RFC 5280 which states CAs **SHOULD NOT** include URIs that specify https, ldaps, or similar schemes in extensions. For OCSP, follow RFC 6960 which states a CA may use port 443 for OCSP where privacy is a requirement. Agencies are encouraged to operate OCSP and CRL services via hostnames specifically reserved for those services, so that other related information and functionality can be served securely and privately. For more information see the Federal CIO Council HTTPS-Only Standard .

Prerequisites

- The server that hosts the CA must be joined to the domain.
- The CA should **never** reside on the same server(s) that are acting as domain controller(s).
- You must be an Enterprise Administrator in the domain to perform these steps.

Install CA Role

1. Log into the **CA server** as a member of the **Enterprise Administrators** group.
2. Open the **Server Manager** and click on **Manage > Add Roles and Features**.
3. Proceed through the **Add Roles and Features Wizard** options. Choose the following:
   Server Roles: ***Active Directory Certificate Services***
   AD CS Roles Services: ***Certification Authority***

4. On the **Results** page, click on **Configure Active Directory Certificate Services on the destination server**.
5. Proceed through the options. Choose the following values, as required:
   Role Service: ***Certification Authority***
   Setup Type: ***Enterprise CA***
   CA Type: ***Root CA***
   Private Key: ***Create a new private key***
   Cryptography: ***RSA#Microsoft Software Key Storage Provider, 2048 bit, SHA-256 6e***
   CA Name: Use the naming convention: **dc=[], dc=[], cn=[*certification authority name*]**
   (e.g., dc=*gov*, dc=*[AgencyName]*, cn=*[AgencyName] NPE CA1*)
   Validity Period: ***6 years***
   Certificate Database: ***<your preference>***

Configure Certificate Template for Domain Controller

The domain controller(s) certificate must contain valid information. These steps provide recommended options and settings.

1. Log into the CA server as a member of the **Enterprise Administrators** group.
2. Open the certificate template's **MMC snap-in** (i.e., **certtmpl.msc**).
3. Right-click on the **Domain Controller Authentication** template. Then, click on **Duplicate Template**.
4. Under the **Compatibility** tab, modify the **Compatibility Settings** for both the *CA* and *certificate recipients* to the highest compatible version (e.g., **Windows Server 2012 R2** or **Windows 2008 R2**).
5. Under the **General** tab, use these recommended settings:
   Template Name: ***<Your organization> - Domain Controller Authentication***.
   Validity Period: ***3 years***.
   Renewal Period: ***6 weeks***.
6. Under the **Cryptography** tab, set these values:
   Minimum Key Size: ***2048***.
   Request Hash: ***SHA256***
7. Open the **CA console** (i.e., certsrv.msc).
8. In the **console tree**, click on the ***[CA's name]***.
9. In the **details** pane, double-click on **Certificate Templates**.
10. In the **console tree**, right-click on **Certificate Templates**. Then, click on **New > Certificate Template To Issue**.
11. Select and enable the ***certificate template*** that was created. Click on **OK**.

Auto-Enroll Domain Controllers Using Group Policy Object (GPO)

1. Log into a **Domain Controller server** as a member of the **Enterprise Administrators** group.
2. Open the **GPMC**: gpmc.msc
3. Within the appropriate **GPO** applied to the Domain Controllers, go to **Computer Configuration\Policies\Windows Settings\Security Settings\Public Key Policies**\
4. Configure **Certificate Services Client – Auto-Enrollment** with the following options:
   Configuration Model: ***Enabled***.
   Renew Expired Certificates, Update Pending Certificates, Remove Revoked Certificates: ***Check_all checkboxes***.
   Update Certificates That Use Certificate Templates: ***Check the checkbox***.
5. Replicate the group policy. Use the command: ***gpupdate /force*** at the command line, or wait for the group policy to replicate based on your replication time and settings.
6. Open **MMC.exe -> File -> Add/Remove Snap-in -> Certificates -> Computer account -> Local computer**.

If successful, you will see a new domain controller certificate in the ***Certificate (Local Computer) -> Personal -> Certificates folder***. At the **Certificate Template** tab, you will also see a certificate generated with the custom certificate template.

Step 8 - Authentication Assurance

When a user authenticates to your network and you've enabled Single Sign-on to applications inside your network domain, you need to know which of these authenticators was used:

- A username and password
- A PIV credential
- An alternate authenticator

You need to know the type of authenticator to implement increasingly granular authorization policies and to grant or deny a user access to information available from applications and shared network resources.

To grant a user access, based on the type of authenticator used, you can use a Windows Active Directory (AD) feature called *Authentication Mechanism Assurance (AMA)*. AMA allows you to add a group membership identifier to the user's Kerberos token.

Do not uses AMA to provide privileged access

Privileged users should not rely on single sign-on and should always use the highest assurance credential. Their account should be separate and distinct from their normal user account. See the Privileged Identity Playbook for best practices in reducing risk associated with privileged accounts and access.

AMA is available for Windows Server 2008 R2 domains and later versions.

Implementation

You can use this PowerShell script CertificateIssuanceOIDs.ps1 to import and set up a list of certificate issuance policies. This script:

- Contains a list of certificate issuance policy object identifiers (OIDs) used by U.S. federal government agencies
- Creates security groups with the same names as the policies
- Links the policies to the security groups

You can run the script with a few simple steps.

- You'll need to specify the Group Distinguished Name (GroupDN) within the script. This targets where you want to create the security groups in your network directory:
    - `CertificateIssuanceOIDs.ps1 -GroupDN \<group DN string>`
    - For example: `CertificateIssuanceOIDs.ps1 -GroupDN 'OU=Groups,OU=Administrators,DC=agency,DC=gov'`
- After downloading this script, you may need to change the PowerShell script execution policy to execute the script or sign the script to execute it.

A sample output from the script is shown below:

```
PS C:\> C:\AMA\Script\CertificateIssuanceOIDs.ps1
-GroupDN 'ou=groups,ou=security,dc=agency,dc=gov'

Created CN=id-fpki-common-authentication,ou=groups,
ou=security,dc=agency,dc=gov
2.16.840.1.101.3.2.1.3.13 -- Unknown ObjectId

Localized name added to DS store.
0: 1033,id-fpki-common-authentication
CertUtil: -oid command completed successfully.

Created CN=13.255922318A2AF32EC47D5B70735D4DB3,
CN=OID,CN=Public Key Services,CN=Services,
CN=Configuration,DC=agency,DC=gov
AD AMA set for 2.16.840.1.101.3.2.1.3.13  id-fpki-common-authentication
```

Note: If the GroupDN is not entered in the command line when executing the script, it will prompt for the input.

```
  PS C:\> C:\AMA\Script\CertificateIssuanceOIDs.ps1
  cmdlet ama-script.ps1 at command pipeline position 1
  Supply values for the following parameters:
  GroupDN: ou=groups,ou=security,dc=agency,dc=gov
==============================================
  GroupDN entered is ou=groups,ou=security,dc=agency,dc=gov
```

Testing

To test the output on your network domain, log in with your PIV credential and check the groups assigned.

- Authenticate with your PIV credential
- From the command line: `C:\whoami /groups`

```
agency\id-fpki-common-authentication   Group  S-1-5-21-179144328
1-1764752353-2202401552-1113
Mandatory group, Enabled by default, Enabled group
```

Use Case Scenarios

Authentication Pass-Through to a Federation Service

A federal employee authenticates to the agency's intranet using a PIV credential and attempts to access an application hosted by a different federal agency.

- The application is restricted to allow access only for users who have authenticated with a valid PIV Authentication certificate.
- All other users are denied access to the application.

This federal employee successfully accesses the other federal agency's application with minimal inputs. The employee is successful because:

- The employee's home agency has a Federation Service installed, and
- The employee's home agency has integrated with the other agency's Federation Service

During and after the employee's logon to the network, the following steps were executed without the employee's intervention:

1. The PIV authentication certificate is parsed
2. The certificate policy OID asserted allows Microsoft AD on the home agency's network to assign the user to a group specifically for PIV authenticated users
3. The user's session is granted a Kerberos ticket that includes the additional group membership

4. The user browses to the other federal agency's application
5. The user's browser is redirected to his/her home agency's Federation Service
6. The Federation Service at the home agency finds the Kerberos ticket for the user's session
7. A Security Assertion Markup Language (SAML) assertion is created by the Federation Service (This is a token translation.)
8. The SAML assertion includes the AD group membership information that identifies that this user authenticated with a PIV credential
9. The user's browser is redirected back to the other federal agency's application
10. The user is successfully authenticated with the valid SAML assertion
11. The other federal agency's application is configured to allow access to only those users who have authenticated using a PIV credential

In this use case and steps, the user did **not** have to authenticate directly with a PIV credential to the other agency's application. A federation model was used.

One example for viewing this implementation pattern is Max.gov. If you click the upper left-hand Login button, you'll see the Max.gov Login page. The bottom section allows you to select an agency. Each of these icons redirects the user back to that agency's Federation Service.

Authentication Pass-Through for Integrated Windows Authentication

A federal employee authenticates to his/her agency's intranet using a PIV credential and attempts to access a local SharePoint site.

- The SharePoint site is restricted to allow access only for those users who have authenticated with a PIV Authentication certificate.
- All other users are denied access to the SharePoint site.

The federal employee successfully accesses the local SharePoint site.

During and after the employee's logon to the network and attempt to access the SharePoint site, the following steps were executed without the employee's intervention:

1. The PIV authentication certificate is parsed
2. The certificate policy OID asserted allows Microsoft AD on the home agency's network to assign the user to a group specifically for PIV authenticated users
3. The user's session is granted a Kerberos ticket that includes the additional group membership
4. The SharePoint site is configured to only allow access to only those users who have authenticated using a PIV credential

Other Considerations and References

Use the Windows Registry Editor to set the *AMA Priority* above *Most Recently Issued Superior Certificate Heuristic*:

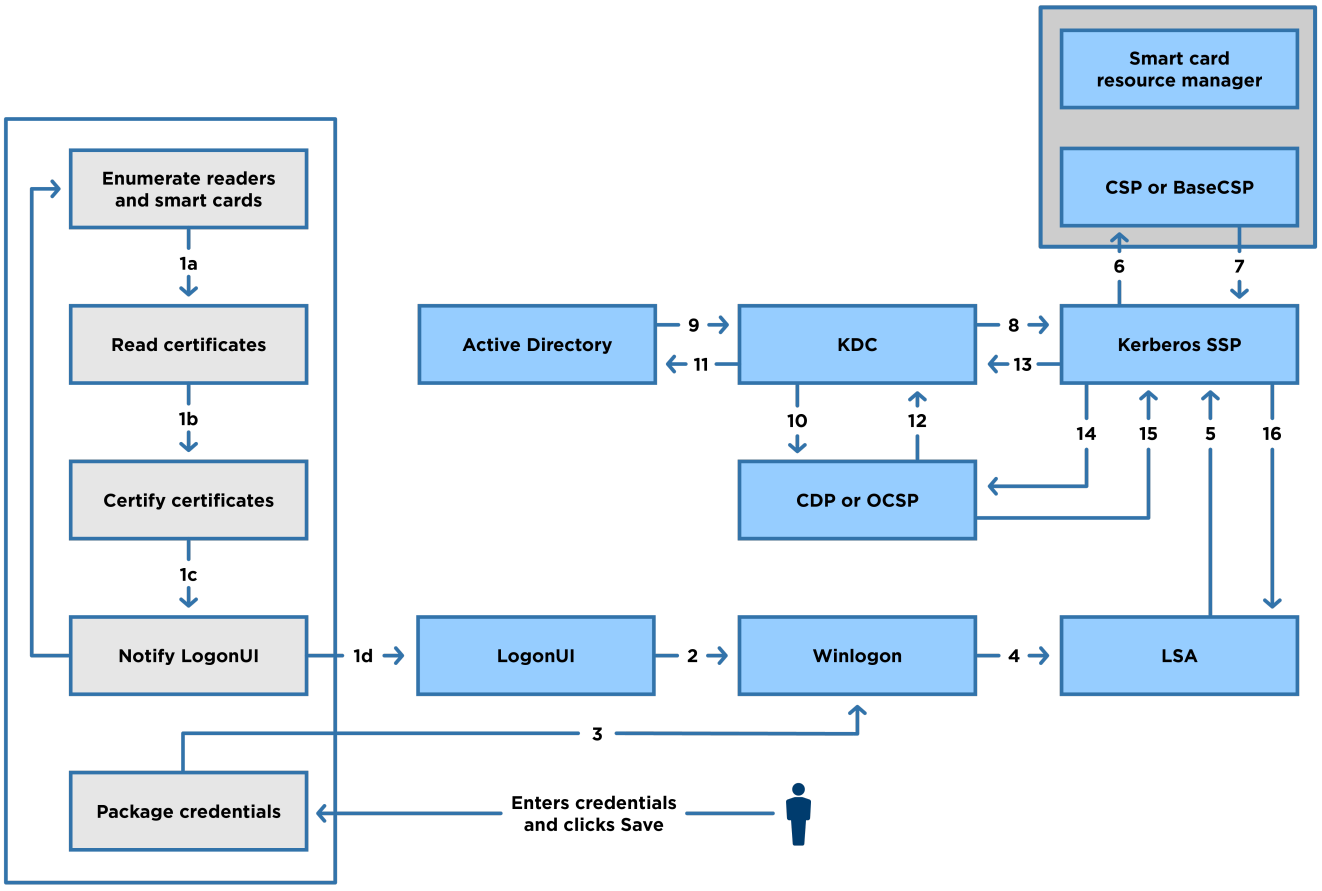
- `[HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\services\kdc]`
- `"ChainWithIssuancePolicyOIDs"=dword:00000001`

Refer to the AMA Step-by-Step Guide to understand the implementation of AMA.

Within the federal enterprise, Windows smart card logon with a PIV card (PIV logon) is one method to satisfy Federal Information Security Management Act (FISMA) and National Institute of Standards and Technology (NIST) Risk Management Framework security controls for authentication. A PIV card enables Authenticator Assurance Level 3, two-factor authentication to a Windows desktop. Under normal conditions, this system is

simple and easy for an end user to use. However, if this logon mechanism breaks, it can be difficult to troubleshoot logon and authentication errors. This page includes common symptoms and suggested steps to diagnose and solve these issues.

The figure below, from the “Smart card sign-in flow in Windows” section of the Microsoft Certificate Requirements and Enumeration article, provides a detailed overview of how smart card logon works in supported versions of Windows.



For our use, this complex process is simplified into the following workflows:

IDManagement.gov

An official website of the U.S. General Services Administration

Looking for U.S. government information and services?

Visit USA.gov Edit this page